

Week 7 Lab – Audit of Vulnerable Bank APIs for Cardholder Data Exposure and PCI DSS–Aligned Remediation

Auditor: Blessing Isaiah

Report Date: January 24, 2026

Executive Summary

This assessment evaluates the Vulnerable Bank (VB) application with a focus on **cardholder data protection** and **alignment with PCI DSS v4.0 requirements**.

The review is based on previous detailed API security testing reports that identified multiple high-risk weaknesses across authentication, authorization, business logic enforcement, and API consumption.

[Report 1](#), [Report 2](#)

The issues identified represent **systemic control failures** rather than isolated technical defects. Collectively, they expose the application to **financial fraud, regulatory non-compliance, reputational damage, and legal risk**.

This document translates the technical findings into **risk-based control gaps** and proposes **tokenization and encryption-focused remediation measures**, explicitly mapped to PCI DSS requirements.

1. Scope and Control Framework

1.1 Scope

- Vulnerable Bank application APIs handling accounts, virtual cards, transactions, and loans
- Authentication, authorization, and session management mechanisms
- Token handling and API inventory accuracy

1.2 Control Frameworks Applied

- PCI DSS v4.0
- OWASP API Security Top 10 (2023)
- NIST SP 800-53 (Access Control, Identification and Authentication, System Communications, Audit Logging)
- GDPR data protection principles

2. Cardholder Data Risk Identification

2.1 Definition of Cardholder Data Risk

Under PCI DSS, cardholder data includes not only the Primary Account Number (PAN), but also **any data element that can be used to access, manipulate, or infer card-based financial value**.

Within the Vulnerable Bank application, the following elements were identified as **in-scope cardholder data assets**:

- Virtual card identifiers
- Card balances and spending limits
- Card transaction histories
- Card operational states (active, frozen)

These elements are considered **high-risk regulated data** due to their direct linkage to financial value.

2.2 Key Risk Scenarios Identified

Risk 1: Unauthorized Access to Cardholder Data (BOLA)

Endpoints

- *GET /api/virtual-cards/{card_id}*
- *GET /api/virtual-cards/{card_id}/transactions*
- *POST /api/virtual-cards/{card_id}/update-limit*
- *POST /api/virtual-cards/{card_id}/toggle-freeze*

Control Gap

Object-level authorization checks are missing. Card identifiers supplied by the client are trusted without ownership validation.

Risk Statement

Unauthorized users can access or manipulate cardholder data belonging to other customers, compromising confidentiality and integrity.

Compliance Impact

- PCI DSS Requirement 7 (Restrict access by business need to know)
- PCI DSS Requirement 8 (Identify and authenticate access)

Risk Rating

Critical

Risk 2: Privilege Escalation via Token Mismanagement (BOPLA)

Leak Mechanism

- JWT contains:
 - is_admin
 - user role data
 - card-related properties
- Token can be modified and re-signed due to weak secret

Control Gap

Authorization decisions rely on client-controlled token properties, and weak cryptographic controls allow token manipulation.

Risk Statement

Attackers can escalate privileges and gain administrative access, enabling broad exposure of cardholder data.

Compliance Impact

- PCI DSS Requirement 8 (Strong authentication and session controls)
- PCI DSS Requirement 3 (Protection of stored cardholder data)

Risk Rating

Critical

Risk 3: Cross-Origin Cardholder Data Exfiltration (CORS Misconfiguration)**Control Gap**

Arbitrary origins are allowed with credentials, and origin validation is absent.

Risk Statement

Authenticated cardholder data can be exfiltrated through malicious websites without direct API access.

Compliance Impact

- PCI DSS Requirement 6 (Develop and maintain secure systems)
- PCI DSS Requirement 7 (Access restrictions)

Risk Rating

High

Risk 4: Unsafe API Consumption and Internal Exposure (SSRF)**Control Gap**

User-supplied URLs are fetched server-side without proper validation or network restrictions.

Risk Statement

Internal services and sensitive resources may be exposed indirectly, increasing breach scope and impact.

Compliance Impact

- PCI DSS Requirement 6 (Secure coding practices)
- PCI DSS Requirement 3 (Data protection)

Risk Rating

High

3. Remediation Strategy: Tokenization and Encryption Controls

3.1 Tokenization of Card Identifiers

Objective

Eliminate direct exposure of regulated card identifiers across API responses and requests.

Control Description

- Replace real card identifiers with non-reversible, randomly generated tokens
- Store token-to-card mappings in a secured vault
- Restrict vault access based on least privilege

Risk Reduction Outcome

- Removes card identifiers from API exposure
- Prevents enumeration and replay attacks
- Reduces regulatory impact in the event of a breach

PCI DSS Mapping

- Requirement 3.4: Render PAN unreadable using tokenization
- Requirement 3.3: Mask PAN when displayed
- Requirement 3.2: Prohibit storage of sensitive authentication data

3.2 Encryption of Cardholder Data at Rest

Objective

Preserve confidentiality of stored cardholder data.

Control Description

- Encrypt balances, limits, and transaction data using AES-256
- Centralize cryptographic key management
- Enforce key rotation and access logging

PCI DSS Mapping

- Requirement 3.5: Protect cryptographic keys
- Requirement 3.6: Key management lifecycle controls

3.3 Authentication and Token Governance

Objective

Prevent unauthorized access and privilege escalation.

Control Description

- Remove sensitive authorization attributes from tokens
- Use asymmetric token signing algorithms
- Implement token invalidation upon logout
- Prevent mass assignment of authorization fields

PCI DSS Mapping

- Requirement 8.2: Strong authentication mechanisms
- Requirement 8.3: Secure session management
- Requirement 8.5: Prevent reuse of authentication credentials

3.4 Authorization and Ownership Enforcement

Objective

Ensure access to cardholder data is strictly limited to authorized users.

Control Description

- Enforce ownership validation on every card-related request
- Centralize authorization logic server-side
- Separate request initiation from approval actions

PCI DSS Mapping

- Requirement 7.2: Restrict access by business need
- Requirement 7.3: Enforce least privilege

3.5 Encryption in Transit

Objective

Protect cardholder data during transmission.

Control Description

- Enforce TLS 1.2 or higher
- Disable plaintext HTTP access
- Apply secure cookie attributes

PCI DSS Mapping

- Requirement 4.1: Encrypt cardholder data over open networks

3.6 Secure Configuration and CORS Enforcement

Objective

Prevent data exposure caused by misconfiguration.

Control Description

- Enforce strict CORS *allowlists*
- Prohibit wildcard origins when credentials are used
- Standardize secure configuration baselines

PCI DSS Mapping

- Requirement 6.4: Secure configuration and change management

- Requirement 7.2: Restrict access to system components

3.7 Logging, Monitoring, and Auditability

Objective

Enable detection, investigation, and accountability for cardholder data access.

Control Description

- Log all card token access and modifications
- Monitor abnormal transaction patterns
- Retain logs according to compliance requirements

PCI DSS Mapping

- Requirement 10.2: Implement audit logging
- Requirement 10.7: Retain logs for forensic analysis

4. Summary of PCI DSS Control Alignment

Security Control	PCI DSS Requirement
Card tokenization	3.4
Encryption at rest	3.5, 3.6
Secure authentication	8.2, 8.3
Token invalidation	8.5
Authorization enforcement	7.2, 7.3
TLS enforcement	4.1
Secure configuration / CORS	6.4
Logging and monitoring	10.2, 10.7

5. Conclusion

The Vulnerable Bank application exhibits multiple high-impact weaknesses that expose cardholder data through inadequate authorization controls, insecure token handling, and unsafe API design practices. These deficiencies violate several PCI DSS requirements and present a **Critical overall risk**.

Implementing **tokenization as the primary protective control**, supported by encryption, hardened authentication, strict authorization enforcement, and comprehensive monitoring, will materially reduce both the likelihood and impact of cardholder data compromise.

Without these controls, the application remains exposed to financial loss, regulatory penalties, and loss of customer trust.